

1. EXECUTIVE SUMMARY

White Plains Hospital conducted a vendor risk assessment of MedBill Pro Solutions LLC, a healthcare IT vendor providing EHR billing and revenue cycle management services. The assessment evaluated 36 security controls across 7 risk categories using a structured security questionnaire, SOC 2 Type 2 review, and document analysis. The vendor achieved a score of 95% (171/180 points), with 4 gaps identified. The assessment result is: APPROVED.

2. FORMAL RECOMMENDATION

RECOMMENDATION: APPROVED

Vendor meets security requirements for handling PHI. Proceed with contract. Schedule annual review.

3. CONDITIONS AND REQUIREMENTS

REQUIRED BEFORE CONTRACT SIGNING

- Signed Business Associate Agreement (BAA) — confirming PHI protection obligations
- Copy of current SOC 2 Type 2 report — dated within 12 months
- Confirmation of cyber liability insurance coverage of minimum \$5 million
- Completed and signed security questionnaire with attestation

REQUIRED WITHIN 90 DAYS OF CONTRACT START

- Remediation plan for identified gaps — specifically MFA on legacy billing module
- Fourth-party risk management program — documenting all subcontractors handling PHI
- Annual security assessment schedule — including dates and assigned contacts

ONGOING REQUIREMENTS — THROUGHOUT CONTRACT PERIOD

- Annual vendor reassessment — using this questionnaire framework
- Incident notification to White Plains Hospital within 4 hours of any PHI incident
- Annual SOC 2 Type 2 report provided to White Plains Hospital GRC team
- Notification of any material change to security controls, ownership, or subcontractors

4. IDENTIFIED GAPS AND REMEDIATION REQUIREMENTS

Gap #	Category	Gap Description	Current Score	Priority	Remediation Action	Due Date
1	Organizational Security	One minor phishing incident in 2023. Contained in 4 hours. No PHI exposed. Post-incident review documentation not yet provided to WPH.	3/5	Medium	incident post-incident review report. Confirm no PHI was exposed. Add as annual requirement in	90 days
2	Data Protection & Privacy	MFA not implemented on legacy billing module. This system processes PHI. Authentication relies on password only.	2/5	High	provide written MFA remediation plan for legacy billing module within 30 days of contract	90 days
3	Compliance & Certifications	No formal fourth-party risk program. Subcontractors handling PHI are not all assessed. Risk of uncontrolled PHI access through supply chain.	2/5	High	complete fourth-party subcontractor register within 60 days. All PHI-handling subcontractors	90 days
4	Vendor & Contract Management	Subcontractor register exists but fourth-party risk assessment program is incomplete. Annual review process not formalized.	4/5	Medium	register is current and shared with WPH annually. Include in annual review checklist.	90 days

5. SOC 2 TYPE 2 REVIEW FINDINGS

MedBill Pro Solutions provided their SOC 2 Type 2 report dated

- Trust Service Criteria

Covered: Security (CC), Availability (A), Confidentiality (C) — all three applicable criteria included

• **Auditor Opinion:** Unqualified opinion — no material control failures noted during audit period

• **Control Exceptions**

Noted: Zero control exceptions noted for Security and Confidentiality criteria
Exception: SLA monitoring alert
Listed: (identity), Twilio (SMS)

• **WPH Assessment:**

5. ASSESSMENT SIGN-OFF				
Assessed By	Nadhir Choudhury — GRC Analyst		Date: April 2026	
Reviewed By	Chief Information Security Officer		Date: _____	
Approved By	Chief Compliance Officer		Date: _____	
Vendor Acknowledged By	MedBill Pro Solutions — Security Officer		Date: _____	